

Rockwell Automation Firmware Attack Surface & Detection Brief

Scope: ~12 product families across 7 architecture classes. Firmware extraction **pending** — staging only, no unique-hash counts yet. Findings combine CVE/PSIRT research (Rockwell Trust Center, CISA ICSAs, Claroty Team82, Dragos, Forescout, Armis) with vendor architecture documentation. Intent: prime detection engineering and prioritize triage classes before firmware is pulled and statistically differenced.

Purdue layer mapping: ControlLogix/GuardLogix (Group A), CompactLogix/Compact GuardLogix (Group B), Micro800 (Group C), and PowerFlex drives (Group F) live at **Purdue L1 (Basic Controllers)** — with the GuardLogix safety variants in A/B also on the **Safety Systems** branch. FactoryTalk SCADA/HMI server (Group D) and Studio 5000 + engineering WS (Group E) live at **Purdue L3 (Site Operations)**. Stratix industrial switches (Group G) sit at **Purdue L3.5 (IT/OT Boundary)**. See [purdue-l1-basic-controllers-brief.md](#), [purdue-l3-site-operations-brief.md](#), [purdue-safety-systems-brief.md](#), and [purdue-l35-it-ot-boundary-brief.md](#) for cross-vendor views.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. ControlLogix / GuardLogix	L1 Basic Controllers (GuardLogix → Safety)	1756-L8x (5580), 1756-L7x (5570), 1756-EN2T/EN2TR/EN3TR/EN4TR comms modules	VxWorks 6.x / 7.x on PPC, CIP over EtherNet/IP (TCP/44818, UDP/2222), embedded web (HTTP/80)	research only
B. CompactLogix / Compact GuardLogix	L1 Basic Controllers (Compact GuardLogix → Safety)	5380 (1769-L3xER), 5370 (1769-L1x/L2x/L3x)	VxWorks on ARM/PPC, same CIP/EtherNet/IP stack as Logix	research only
C. Micro800	L1 Basic Controllers	Micro820/830/850/870, 2080-LCxx	proprietary RTOS, CIP + Modbus TCP,	research only

Class	Purdue layer	Products	Stack	Catalog depth
			embedded HTTP, USB	
D. FactoryTalk SCADA/HMI	L3 Site Operations	View SE/ME server, AssetCentre, Historian SE, Linx Gateway, ThinManager	Windows Server + .NET + MSSQL backend, RNA/FTLinx protocols	research only
E. Studio 5000 + engineering WS	L3 Site Operations (EWS)	Studio 5000 Logix Designer, RSLinx Classic, FactoryTalk Linx, Emulate	Windows workstation, FactoryTalk Services Platform	research only
F. PowerFlex drives	L1 Basic Controllers	525/527/753/755/755T, 6000T	embedded MCU + optional 20-COMM-E EtherNet/IP card, CIP, DPI	research only
G. Stratix switches	L3.5 IT/OT Boundary	5700/5400/5410/5800/8000/8300 (Cisco IE OEM)	Cisco IOS or IOS-XE, SNMP, SSH, web	research only

Group A — ControlLogix / GuardLogix (highest blast radius) — Purdue L1 (Basic Controllers; GuardLogix → Safety)

Direct attack surface (per vendor docs + Claroty Team82 research; not yet verified against extracted firmware):

EtherNet/IP CIP (TCP/44818, UDP/2222 implicit I/O) · embedded HTTP (TCP/80)
 · SNMP on EN2T/EN3TR/EN4TR · CIP Security (opt-in) · USB on L8x faceplate

Default factory state: CIP unauthenticated, web UI open, no CIP Security enforcement, controller mode-switch software-overridable when keyswitch in REM.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2023-3596	7.5	1756-EN2T/EN2F/EN2TR/EN3TR/EN4TR	Malformed CIP packet → DoS of comms module	Claroty Team82 disclosure, fixed in v12.001

CVE	CVSS	Product	Vector	Status
CVE-2023-46290	7.5	FactoryTalk Services Platform (touches Logix auth)	Improper auth, unauth user enumeration	patched 6.40
CVE-2024-21915	9.8	FactoryTalk Service Platform	Privilege escalation, affects Logix sessions	ICSA-24-018-01
CVE-2024-6242	8.4	1756-EN4TR	CIP trusted-slot bypass, jump from any chassis slot to controller	Claroty "Bypassing the Trusted Slot"
Claroty Team82 "Evil PLC"	n/a	Logix 5580/5570	Weaponized PLC project file → RCE on engineering WS via Studio 5000	team82 blog

Top attack vector (MITRE ATT&CK ICS): [T0843 Program Download](#) over CIP — direct logic write to controller in RUN/REM. Volt Typhoon's 2024 US-infrastructure campaign (per CISA AA24-038A) included reconnaissance against ControlLogix on water and energy networks.

Group B — CompactLogix / Compact GuardLogix — Purdue L1 (Basic Controllers; Compact GuardLogix → Safety)

Direct attack surface: Identical CIP/EtherNet/IP stack to ControlLogix; integrated Ethernet on the controller itself (no separate EN2T module). Embedded web UI on TCP/80.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2021-22681	10.0	Logix family incl. CompactLogix 5370/5380	Hardcoded cryptographic key in Studio 5000 → remote auth bypass to controller	ICSA-21-056-03 , Claroty/Kaspersky/Otorio co-disclosure
CVE-2022-1161	7.7	CompactLogix 5380/5480, ControlLogix 5580	Stealthy logic injection (Studio 5000 view ≠ controller bytecode)	Claroty Team82 disclosure
CVE-2023-2071	9.8	CompactLogix 5370 + EN2T-class comms	Crafted CIP packet → RCE on controller	ICSA-23-136-04

Top attack vector: [T0831 Manipulation of Control](#) via CIP write, or [T0833 Modify Control Logic](#) using the CVE-2022-1161 "stealth" technique where engineer's online view diverges from running bytecode.

Group C — Micro800 — Purdue L1 (Basic Controllers)

Direct attack surface: CIP + Modbus TCP, embedded HTTP/80, USB programming port. Connected Components Workbench (CCW) is the engineering tool. No keyswitch on entry-level models — mode change is purely software.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2022-3157	7.5	Micro850/870	Crafted CIP → DoS major fault	ICSA-22-256-03
Rockwell PSIRT — CCW project parsing RCE family	varies	CCW engineering tool	Project-file parsing RCE on engineer WS	Rockwell PSIRT advisory family

Top attack vector: [T0858 Change Operating Mode](#) — software-only PROG/RUN switch on Micro800 means a single authenticated CIP session stops the process. No physical keyswitch defense exists.

Group D — FactoryTalk SCADA/HMI server (the Windows-side high-CVSS surface) — Purdue L3 (Site Operations)

Direct attack surface (per Rockwell architecture docs): Windows Server hosting FactoryTalk Directory, View SE Server, AssetCentre, Historian. RNA messaging, FactoryTalk Linx (TCP/3060 + dynamic), HTTP/HTTPS portal, SQL Server backend. AssetCentre stores PLC project archives + credentials.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2024-21915	9.8	FactoryTalk Service Platform	Privilege escalation across FT user store	ICSA-24-018-01
CVE-2024-21914	6.5	FactoryTalk View SE	DoS via crafted message	ICSA-24-018-02
Rockwell PSIRT — FactoryTalk View SE project-import RCE family	high	FactoryTalk View SE	RCE via crafted HMI project import	Rockwell PSIRT advisory family
ICSA-23-193-01 — FactoryTalk View ME family	varies	FactoryTalk View ME	Multiple unauth issues	ICSA-23-193-01
Rockwell PSIRT — AssetCentre deserialization RCE family	high	FactoryTalk AssetCentre	RCE via deserialization of project archive	Rockwell PSIRT advisory family

Top attack vector: [T0855 Unauthorized Command Message](#) combined with [T0852 Screen Capture](#) — once on the HMI server the attacker drives the plant from the console operators trust. AssetCentre compromise hands over every controller credential in one shot.

Group E — Studio 5000 + FactoryTalk Linx engineering workstation — Purdue L3 (Site Operations, EWS)

Direct attack surface: Windows workstation running Studio 5000 Logix Designer, FactoryTalk Linx / RSLinx Classic, FactoryTalk Services Platform. Driver shim that brokers CIP between the engineer and every controller on the network.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2024-45824	9.8	FactoryTalk View ME / Studio 5000	Remote code injection via crafted project	Rockwell PSIRT advisory
Rockwell PSIRT — Studio 5000 DLL hijack family	high	Studio 5000 Logix Designer	DLL hijack on launch	Rockwell PSIRT advisory family
Claroty "Evil PLC"	n/a	Studio 5000	Malicious PLC project file weaponizes the engineering WS	team82 paper

Top attack vector: [T0866 Exploitation of Remote Services](#) — Studio 5000 is the privileged jump host; compromising it gives CIP-Security-bypassing access to every PLC.

Group F — PowerFlex drives — Purdue L1 (Basic Controllers)

Direct attack surface: Drive itself is bare-metal MCU; network exposure is through 20-COMM-E / embedded EtherNet/IP. CIP + DPI peripheral bus. No authentication on legacy 20-COMM-E.

Confirmed CVEs:

CVE	CVSS	Product	Vector	Status
CVE-2022-1794	7.5	PowerFlex 755	Crafted CIP → drive fault / DoS	ICSA-22-153-02

CVE	CVSS	Product	Vector	Status
Rockwell PSIRT — PowerFlex 525 CIP fault family	high	PowerFlex 525	Malformed CIP → persistent fault	Rockwell PSIRT advisory family

Top attack vector: [T0836 Modify Parameter](#) — direct CIP write of speed/accel/torque limits. A motor speed setpoint write outside commissioned bounds is a mechanical-damage attack (centrifuge / pump / conveyor).

Group G — Stratix switches — Purdue L3.5 (IT/OT Boundary)

Direct attack surface: Cisco IE OEM running IOS/IOS-XE. SSH, SNMP, HTTPS web. Inherits Cisco IOS CVE surface entirely.

Top attack vector: [T0830 Adversary-in-the-Middle](#) — switch compromise enables CIP packet manipulation against every Logix controller behind it. Treat as Cisco IE switch for patching cadence; CVEs track Cisco PSIRT, not Rockwell.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Network IDS (Suricata/Zeek)	CIP service codes 0x4B/0x4C/0x4D (program download), 0x52 (forward open from new source IP)	Logic injection / Evil PLC	T0843 Program Download
2	Network IDS	CIP class 0x6B (mode change) on TCP/44818 from non-engineering subnet	Software mode flip (Micro800, CompactLogix)	T0858 Change Operating Mode
3	FactoryTalk Diagnostics	FT Directory <code>LogOn</code> / <code>LogOff</code> correlated with AssetCentre <code>CheckOut</code> of PLC project	Attacker pulling project to weaponize	T0866 Exploitation of Remote Services
4	Network IDS	EtherNet/IP <code>ListIdentity</code> sweep (UDP/44818) from inside enterprise → OT	Pre-attack recon (Volt Typhoon TTP)	T0846 Remote System Discovery

#	Source	Event	What it catches	MITRE ATT&CK ICS
5	Sysmon on engineering WS	EventID 1 ParentImage= RSLogix5000.exe / Studio5000.exe / RSLinx.exe spawning cmd.exe / powershell.exe / rundll32.exe	Evil PLC project file exploitation	T0853 Scripting
6	Sysmon (FactoryTalk server)	EventID 7 ImageLoad on FTAC.exe / FTSecurity.exe / ViewSE*.exe loading DLLs from non-Rockwell paths	DLL hijack on FactoryTalk binaries	T0866 Exploitation of Remote Services
7	Controller audit log via CIP 0xA0	Project download, key-switch position change, controller fault	Direct tamper attempts	T0831 Manipulation of Control
8	Stratix/IE switch syslog	Port-link bounce on PLC port, MAC move on controller IP	AitM insertion, rogue device	T0830 Adversary-in-the-Middle

Secondary:

- Firewall: any egress from OT VLAN to non-RFC1918 — Logix controllers should never originate outbound to internet (Volt Typhoon callback path).
- FactoryTalk Diagnostics audit categories: Audit, Security, Configuration — ship to SIEM via FT-Alarms-and-Events.
- AssetCentre disaster-recovery audit: alert on every PLC project check-out that does not match a change-ticket window.
- Rockwell PSIRT RSS — subscribe <https://www.rockwellautomation.com/en-us/trust-center/security-advisories.html>.
- OT-native power/process anomalies: PowerFlex speed setpoint write outside commissioned envelope; ControlLogix CPU load spike > 90% without project change (CVE-2023-3596 DoS precursor); GuardLogix safety-task watchdog trip without maintenance window.

Specific zero-day-ish concerns for your dataset

1. **CIP "trusted slot" bypass (CVE-2024-6242) on 1756-EN4TR.** Once firmware is extracted, the EN4TR comms module is the highest-priority target — Claroty showed a jump from any chassis slot to the controller. Confirm whether shipping firmware in the queue is patched (v5.001+).
2. **Stealth logic injection (CVE-2022-1161 class) on CompactLogix 5380.** Studio 5000 caches the project view; the controller bytecode can diverge. Even with extracted firmware in hand, detection

requires comparing the on-controller bytecode hash to the AssetCentre archive hash — flag this as a planned differential-analysis check once 5380 firmware is staged.

3. **Volt Typhoon ControlLogix reconnaissance (CISA AA24-038A).** US-infrastructure campaign attributed by CISA included ListIdentity sweeps against ControlLogix on water/energy networks. If extraction proceeds, snapshot every controller's `0x01 ListIdentity` and `0x66 GetAttributesAll` responses for diffing against known-good baselines.
4. **FactoryTalk AssetCentre as the credential mother lode.** Group D extraction priority should put AssetCentre's encrypted credential vault ahead of View SE; one compromise yields every PLC password in the plant. Confirm DPAPI-MS or Rockwell custom container before triage.

Sources

- [Rockwell Automation Trust Center — Security Advisories](#)
- [CISA ICSA-21-056-03 — Logix Controllers \(CVE-2021-22681\)](#)
- [CISA ICSA-23-136-04 — CompactLogix 5370 CVE-2023-2071](#)
- [CISA ICSA-24-018-01 — FactoryTalk Service Platform CVE-2024-21915](#)
- [CISA ICSA-22-153-02 — PowerFlex 755](#)
- [CISA AA24-038A — Volt Typhoon US Critical Infrastructure](#)
- [Claroty Team82 — Evil PLC Attack \(Rockwell/Logix\)](#)
- [Claroty Team82 — Stealthy Rockwell PLC Hack \(CVE-2022-1161\)](#)
- [Claroty Team82 — Bypassing Trusted Slot on 1756-EN4TR \(CVE-2024-6242\)](#)
- [Dragos — ICS Cybersecurity Year in Review \(CIP / Rockwell coverage\)](#)
- [Forescout 2025 OT Threat Report](#)
- [MITRE ATT&CK for ICS — T0843 Program Download](#)
- [MITRE ATT&CK for ICS — T0858 Change Operating Mode](#)
- [MITRE ATT&CK for ICS — T0833 Modify Control Logic](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)